UNIVERSIDAD MADERO

LICENCIATURA EN INGENIERÍA EN SEGURIDAD INFORMÁTICA Y REDES

Matricula:

20145025

Semestre:

3er. Semestre

Alumno:

Gabriel René Díaz Lara

Materia:

Delitos Cibernéticos

Docente:

Dulce María Vázquez Caro

Fecha:

Septiembre 2026

Contenido

1. **Introducción** 3
2. **Narración del Caso.** 4
3. **Taxonomía del delito.** 5
4. **Técnicas de hackeo utilizadas** 6
5. **Vector de Ataque** 7
6. **Hallazgos forenses** 9
7. **Fundamentación jurídica aplicable en México** 10
8. **Dependencias que deben intervenir** 12
9. **Conclusión** 13
10. **Bibliografía** 14

Actividad 1. Análisis Integral de un Delito Cibernético.

1. Introducción

El presente informe tiene como objetivo desarrollar un análisis técnico y jurídico de los ataques cibernéticos ocurridos entre abril y mayo de 2018 contra cinco participantes del Sistema de Pagos Electrónicos Interbancarios (SPEI). El documento oficial emitido por Banco de México en su Informe Trimestral de ese periodo constituye la fuente principal de los hechos, y por eso se toma como punto de partida para reconstruir lo que realmente ocurrió.

Aunque en un primer momento se habló de un ataque masivo al sistema de pagos, el propio Banco de México fue claro al precisar que el núcleo del SPEI nunca fue comprometido. Lo que se vulneró fueron los aplicativos de conexión que utilizan algunas instituciones para enviar órdenes de pago. Esa distinción es importante porque cambia el alcance del incidente y también las responsabilidades que se derivan.

El objetivo de este trabajo es doble. Por un lado, desglosar el incidente utilizando el marco de MITRE ATT&CK para entender cómo operó el atacante en términos técnicos. Por otro, relacionar esos hallazgos con el marco normativo mexicano vigente en ese momento, especialmente el Código Penal Federal y la regulación aplicable al sistema financiero. No se busca atribuir autoría (las investigaciones seguían en curso según el propio informe), sino analizar el vector de ataque, la evidencia que podría haberse preservado y las implicaciones jurídicas que un caso de este tipo genera en México.

El análisis se estructura siguiendo la Narración del Caso, Taxonomía del delito, Técnicas de Hackeo utilizadas, Vector de Ataque, Hallazgos Forenses, Fundamentación jurídica aplicable en México, Dependencia que debe intervenir y Conclusiones. Se parte de la narración de los hechos tal como los documentó Banco de México, se clasifica el incidente según una taxonomía técnica, se desglosa el vector de ataque y se identifican los elementos de evidencia digital que resultarían relevantes en una investigación. Posteriormente se revisa la fundamentación jurídica aplicable y las autoridades que tendrían competencia. Al final se ofrecen conclusiones que buscan ir más allá de una lista de recomendaciones genéricas.

El caso resulta particularmente útil para un análisis de este tipo porque combina elementos técnicos claros con un contexto regulatorio específico del sistema financiero mexicano. Además, permite observar cómo una vulneración en la periferia del sistema (los aplicativos de los participantes) puede generar afectaciones operativas y de confianza que van más allá del daño económico directo.

2. Narración del Caso.

Entre abril y mayo de 2018, cinco participantes del SPEI fueron objeto de ataques que se centraron en los aplicativos que usan para generar y enviar órdenes de pago al sistema. El informe de Banco de México es bastante directo al respecto: el núcleo del SPEI nunca fue comprometido. Lo que se vulneró fueron las aplicaciones periféricas de conexión de algunas instituciones financieras.

Los eventos se concentraron en fechas muy específicas. El primero se detectó el 17 de abril. Después vinieron dos más el 24 de abril, otro el 26 y el último el 8 de mayo. En todos los casos el atacante logró insertar transacciones ilegítimas dentro del flujo normal de los aplicativos. Estas operaciones tenían una particularidad: la cuenta emisora no existía, mientras que la receptora sí era real. Una vez que el participante afectado firmaba y enviaba la instrucción, el SPEI la procesaba como válida y los recursos llegaban a las cuentas destino, desde donde eran retirados en efectivo.

Aunque los recursos de los clientes de los bancos nunca estuvieron en riesgo —porque se encuentran en sistemas separados con validaciones individuales por operación—, el incidente sí generó una ralentización en el procesamiento de pagos para las operaciones que involucraban a las instituciones afectadas. Banco de México tuvo que activar esquemas de contingencia, como el Cliente de Operación Alterno (COAS), para que los participantes pudieran seguir operando mientras se estabilizaban sus sistemas.

Lo que llama la atención es que el daño no se limitó al aspecto técnico. Las instituciones afectadas tuvieron que migrar a plataformas de contingencia, reforzar monitoreo y rehacer procesos de conexión. Eso implica costos operativos que no se cuantificaron públicamente en el informe, pero que evidentemente fueron relevantes. En el plano reputacional, el hecho de que se emitieran varios comunicados de prensa y que el propio Banco de México tuviera que salir a aclarar que los recursos de los clientes estaban seguros ya da cuenta de que el impacto fue más allá del daño económico directo.

Un detalle que vale la pena retomar es que en la mayoría de los casos los aplicativos comprometidos habían sido desarrollados por terceros. Esto no exime de responsabilidad a las instituciones, pero sí añade una capa de complejidad cuando se trata de determinar dónde fallaron los controles de seguridad. El informe menciona que Banco de México no ofrece ni certifica estos aplicativos, por lo que cada participante es responsable de su implementación y operación.

En términos generales, el caso muestra cómo una vulneración en la periferia del sistema de pagos puede generar afectaciones operativas y de confianza que van más allá del monto defraudado.

3. Taxonomía del delito.

El incidente se puede clasificar como un delito de ***fraude informático con elementos de acceso ilícito y manipulación de datos.*** Aunque el sistema central del SPEI no fue vulnerado, los atacantes lograron insertar transacciones falsas dentro del flujo operativo de las instituciones. Este tipo de ataque encaja dentro del Código Penal Federal, que sanciona en los artículos relacionados con el acceso no autorizado y la alteración de información en sistemas informáticos.

El objetivo del atacante fue claramente económico. No se trató de un ataque de denegación de servicio ni de una acción con fines políticos o de visibilidad. El propósito era generar transferencias ilegítimas que pudieran ser retiradas en efectivo antes de que las instituciones detectaran la anomalía. Esto lo diferencia de otros incidentes más orientados a la exfiltración masiva de datos o al ransomware.

En cuanto a las técnicas empleadas, el marco de MITRE ATT&CK resulta útil para ordenar lo que ocurrió. El atacante inició con un acceso inicial a la infraestructura de los participantes, probablemente mediante la explotación de vulnerabilidades en los aplicativos de conexión o en la red donde estos se ejecutaban. Posteriormente se observa ejecución de código malicioso para insertar las transacciones fraudulentas, y es muy probable que haya existido alguna forma de persistencia para mantener el control durante el tiempo necesario para generar las operaciones. La escalada de privilegios y el movimiento lateral dentro de la red del participante también son elementos que se pueden inferir, aunque el informe de Banco de México no detalla el nivel técnico de cada compromiso.

Los activos comprometidos fueron principalmente los aplicativos de conexión al SPEI desarrollados por terceros y la infraestructura de cómputo y telecomunicaciones de las instituciones afectadas. No se vulneraron los sistemas centrales de Banco de

México ni las cuentas de los clientes finales, lo cual es un punto importante porque limita el alcance del daño.

La afectación generada fue mixta. Por un lado, hubo un impacto directo en la integridad de las operaciones del sistema de pagos, ya que se procesaron transacciones fraudulentas. Por otro, se generó una afectación operativa significativa al obligar a varias instituciones a migrar a esquemas de contingencia, lo que ralentizó el procesamiento de pagos legítimos durante varias semanas. Aunque no se reportó una pérdida masiva de recursos de clientes, el incidente sí expuso debilidades en los controles de las instituciones participantes y generó un costo reputacional para el sistema de pagos electrónico en su conjunto.

4. Técnicas de hackeo utilizadas

Antes de entrar en materia, hay que hacer una aclaración metodológica que no conviene saltarse. El informe de Banco de México confirma que los atacantes vulneraron la infraestructura tecnológica de los participantes e insertaron transacciones ilegítimas en los aplicativos de conexión al SPEI, pero en ningún momento publica detalles forenses sobre el método de acceso ni sobre las herramientas empleadas. Lo que sigue, entonces, es una reconstrucción técnica plausible apoyada en cómo suelen operar este tipo de ataques (y en lo poco que sí documenta la fuente oficial), no una confirmación de las técnicas realmente utilizadas.

Lo que sí se observa, porque está en el propio informe, es que los atacantes lograron vulnerar la infraestructura de los participantes e insertar transacciones ilegítimas en alguna etapa del proceso que realizan los aplicativos de conexión al SPEI. Esto sugiere que el compromiso ocurrió antes de que la firma digital de la institución se aplicara a la operación. Es decir, el atacante no necesitó romper la firma del SPEI, sino que logró que el propio participante firmara y enviara operaciones fraudulentas. Este dato sí está confirmado; lo que viene después ya no.

Desde la perspectiva de MITRE ATT&CK, lo más probable es que se haya utilizado una combinación de técnicas de las tácticas de **Initial Access** y **Execution**, aunque conviene remarcarlo: es una hipótesis compatible con los hechos, no una técnica identificada por Banco de México. El hecho de que en todos los casos los aplicativos comprometidos fueran desarrollados por terceros abre la posibilidad de que el vector haya sido una vulnerabilidad en el software de conexión o en la forma en que este interactuaba con la infraestructura del banco. También es factible que se haya

explotado algún mecanismo de autenticación débil o que se haya realizado una inyección de código en el flujo de preparación de las órdenes de pago, pero ninguna de estas opciones puede confirmarse con la información pública disponible.

Una vez dentro, el atacante habría requerido modificar el comportamiento del aplicativo para generar transacciones con cuentas emisoras inexistentes. Esto implica algún nivel de ejecución de código arbitrario o manipulación de la lógica de la aplicación (otra vez, hablando en términos de lo que sería necesario para lograr el resultado descrito, no de lo que se probó que ocurrió). El informe menciona que las transacciones ilegítimas se insertaron "en alguna etapa del proceso", lo que podría ser compatible con técnicas como **Process Injection** o manipulación de memoria, aunque no hay evidencia pública que confirme el método exacto utilizado.

Lo que sí queda claro, y esto ya no es hipótesis, es que el atacante no requirió un malware altamente sofisticado ni técnicas avanzadas de evasión de defensas para lograr el objetivo descrito. Bastó con comprometer el punto de generación de las órdenes de pago para que el resto del flujo (firma del participante y validación del SPEI) operara de forma normal. Esto es consistente con ataques que priorizan el control del punto de origen de la transacción antes que el compromiso del sistema central.

Un aspecto que vale la pena señalar es que el informe no menciona el uso de herramientas específicas ni la presencia de artefactos maliciosos conocidos. Esto limita bastante el análisis técnico, pero también refleja una realidad común en incidentes financieros: muchas veces las instituciones priorizan la contención y la recuperación operativa por encima de la preservación exhaustiva de evidencia forense, que es justo lo que habría permitido pasar de la hipótesis al hecho confirmado.

5. Vector de Ataque

La siguiente reconstrucción no debe leerse como una cronología forense confirmada en todos sus elementos. Banco de México documentó la vulneración de la infraestructura de los participantes, la inserción de transferencias ilegítimas y el posterior retiro de recursos; las fases de acceso inicial, escalada de privilegios, movimiento lateral y persistencia que se describen a continuación se presentan como una hipótesis analítica, ordenada con apoyo del marco MITRE ATT&CK, para explicar de forma coherente el posible comportamiento del atacante.

El acceso inicial probablemente ocurrió a través de la infraestructura de los participantes. El informe señala —esto sí de forma confirmada— que los atacantes vulneraron la infraestructura tecnológica de las instituciones e insertaron

transacciones ilegítimas en alguna etapa del proceso de los aplicativos de conexión. De ahí en adelante entramos al terreno hipotético: el vector más probable habría sido la explotación de vulnerabilidades en los aplicativos desarrollados por terceros o en los servidores donde estos se ejecutaban. No hay evidencia de que se haya utilizado un vector de phishing masivo o de ingeniería social contra usuarios finales, aunque tampoco puede descartarse del todo con la información disponible.

Una vez dentro del ambiente del participante, el atacante habría necesitado capacidad para modificar el flujo de preparación de las órdenes de pago. Aquí es donde entraría la fase de ejecución. Es razonable pensar que se utilizó alguna técnica de inyección o manipulación del proceso del aplicativo para generar transacciones con cuentas emisoras inexistentes, aunque de nuevo se trata de una inferencia, no de un dato confirmado. El hecho de que estas operaciones fueran posteriormente firmadas por el propio participante sí indica —esto lo dice el informe— que el atacante logró operar dentro del flujo normal de la aplicación, en lugar de tener que falsificar firmas digitales del SPEI.

La escalada de privilegios y el movimiento lateral no se mencionan de forma explícita en el documento oficial, y aquí conviene ser honesto: se incluyen porque resultan necesarios para explicar, desde una lógica técnica razonable, cómo el atacante pudo mantener el control suficiente como para generar múltiples transacciones en diferentes momentos (17 y 24 de abril, 26 de abril y 8 de mayo). Es probable, aunque no verificable con la fuente disponible, que una vez dentro de un servidor o segmento de red el atacante haya buscado credenciales o accesos que le permitieran interactuar con el aplicativo de conexión de forma persistente.

La persistencia, si existió, parece haber sido funcional más que sofisticada. El atacante no necesitaba mantener un acceso prolongado y sigiloso; le habría bastado con poder insertar operaciones fraudulentas en los momentos en que el sistema estaba operativo. Esto reduce la necesidad de técnicas avanzadas de persistencia como la instalación de rootkits o backdoors complejos, aunque, insisto, se trata de una lectura razonable del caso y no de un hallazgo forense documentado.

En cuanto a la exfiltración de datos, el informe no reporta robo masivo de información, y esto sí es un dato confirmado por omisión: no se documenta. El objetivo principal fue la inyección de transacciones fraudulentas para generar un beneficio económico directo mediante retiros en efectivo. El impacto final sí está plenamente confirmado: se materializó cuando las operaciones fueron procesadas por el SPEI y los recursos llegaron a las cuentas receptoras, desde donde posteriormente fueron retirados en efectivo.

Lo que resulta interesante de este vector, más allá de qué tan confirmadas estén sus fases intermedias, es su relativa simplicidad de origen. No se requirió comprometer el sistema central de Banco de México ni romper mecanismos de seguridad robustos del SPEI. Bastó con tomar el control del punto donde se originan las órdenes de pago para que todo el flujo posterior las validara como legítimas.

6. Hallazgos forenses

La evidencia digital que permitiría reconstruir y demostrar este incidente se concentra principalmente en los aplicativos de conexión de los participantes afectados y en los registros del propio SPEI. Aunque el informe de Banco de México no entrega un listado detallado de indicadores de compromiso, sí describe el flujo que se alteró, lo que permite identificar qué elementos serían clave en una investigación forense.

Los logs de los aplicativos de conexión serían la evidencia más directa. Estos registros deberían mostrar la inserción de transacciones con cuentas emisoras inexistentes en momentos específicos, así como posibles modificaciones en el flujo normal de preparación de órdenes de pago. También serían relevantes los logs de autenticación y de ejecución de procesos en los servidores donde operaban estos aplicativos, ya que podrían revelar accesos no autorizados o ejecución de código fuera de los patrones habituales.

Las direcciones IP de origen de las conexiones que generaron las transacciones fraudulentas constituirían otro elemento importante. Aunque el atacante pudo haber utilizado técnicas de ofuscación o proxies, los registros de las instituciones receptoras que detectaron operaciones sospechosas podrían ayudar a trazar el origen de las instrucciones. Además, los logs del SPEI central deberían contener las firmas digitales de los participantes que enviaron las operaciones ilegítimas, lo que permitiría identificar con precisión qué instituciones fueron comprometidas y en qué momento.

En cuanto a artefactos digitales, sería necesario revisar si existieron archivos modificados, scripts o configuraciones alteradas dentro de los aplicativos de conexión. Dado que en la mayoría de los casos estos aplicativos fueron desarrollados por terceros, también sería relevante analizar las actualizaciones o parches que se aplicaron en las semanas previas a los ataques, por si alguna de ellas introdujo la vulnerabilidad explotada.

La evidencia documental resulta especialmente valiosa en este caso. Las alertas internas que generaron los propios participantes al detectar operaciones anómalas, así como las notificaciones que recibieron de otras instituciones receptoras,

constituyen registros que permiten establecer la línea de tiempo del incidente. También serían útiles los comunicados internos y los reportes de incidentes que las instituciones afectadas debieron generar al activar sus protocolos de respuesta.

Un aspecto que complica el análisis forense es que el informe no menciona la preservación de hashes de archivos ni la existencia de malware específico. Esto no significa que no haya existido, sino que el enfoque del documento está más orientado a la contención operativa que a la investigación técnica detallada. En una investigación penal real, la recolección de estos elementos habría sido fundamental para determinar el método exacto de compromiso y, eventualmente, para identificar a los responsables.

7. Fundamentación jurídica aplicable en México

Para desenredar las consecuencias legales de lo ocurrido en el SPEI hay que partir de una distinción técnica elemental: las transferencias irregulares no surgieron por generación espontánea, sino que fueron el resultado directo de la vulneración previa a la infraestructura tecnológica de los participantes. El Código Penal Federal (CPF) contempla este escenario con bastante claridad en el Título Noveno, donde tipifica las conductas dirigidas contra sistemas informáticos, estableciendo agravantes específicas cuando el blanco son entidades del sistema financiero mexicano.

El artículo 211 Bis 4 del CPF encaja de forma directa con el núcleo operativo del incidente. Este precepto sanciona a quien, sin autorización, modifique, destruya o provoque la pérdida de información contenida en sistemas o equipos de informática protegidos pertenecientes a instituciones del sistema financiero, así como a quien acceda o copie dicha información. Si bien el informe de Banco de México no detalla la mecánica exacta a bajo nivel (es decir, si hubo una inyección de memoria, alteración de base de datos o reemplazo de binarios), el hecho probado de que se insertaron transacciones ilegítimas con cuentas emisoras inexistentes dentro del flujo del aplicativo ya implica una alteración ilícita del procesamiento de datos en sistemas financieros protegidos.

Conviene no perder de vista el artículo 211 Bis 5 del mismo ordenamiento. Esta figura sanciona las mismas conductas de alteración o acceso indebido, pero cometidas por personas que sí cuentan con autorización de acceso al sistema (la clásica amenaza interna o el uso indebido de credenciales legítimas). Como la fuente oficial no descarta

el compromiso de credenciales operativas para validar o firmar los paquetes antes de su envío al SPEI central, la investigación ministerial tendría que determinar si el atacante operó como un intruso totalmente externo o si abusó de privilegios de cuentas existentes dentro de la entidad bancaria.

A la par del delito informático estricto, surge la vertiente patrimonial. El artículo 386 del CPF contempla el delito de fraude, configurado cuando alguien se hace de una cosa o alcanza un lucro indebido mediante el engaño o aprovechándose del error. En los eventos de 2018, la inyección de instrucciones apócrifas indujo a las plataformas a procesar transferencias hacia cuentas reales para su posterior retiro en efectivo, consumando un quebranto patrimonial directo a las instituciones emisoras. Ambas figuras no se excluyen: una atiende al medio comisivo informático (el acceso y alteración del sistema) y la otra al resultado económico lesivo.

Tampoco hay que mezclar la esfera penal con la administrativa. Las Circulares 14/2017, 4/2018 y 5/2018 emitidas por Banco de México establecen directrices obligatorias de seguridad, monitoreo y continuidad operativa (como el uso del esquema contingente COAS). Su incumplimiento o implementación deficiente no constituye un tipo penal, pero sí fundamenta responsabilidades administrativas ante la Comisión Nacional Bancaria y de Valores e ilustra fallas en el deber de cuidado de las instituciones frente a la regulación financiera.

Respecto a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), su aplicabilidad en este caso resulta meramente marginal. El informe de Banco de México enfatiza que los fondos y las cuentas de los usuarios finales no fueron vulnerados, concentrándose el ataque en los recursos propios de las entidades y en sus pasarelas de conexión. Al no existir evidencia pública de filtración, exfiltración o robo de bases de datos con información sensible de clientes, no se puede sostener jurídicamente una violación a esta ley sin caer en especulaciones.

Todo el soporte probatorio para sostener estas acusaciones descansa en la correcta gestión de la evidencia digital. El Código Nacional de Procedimientos Penales (CNPP), en sus artículos 227 y 228, regula la cadena de custodia y la preservación de los indicios materiales y lógicos del delito. Tratándose de un fraude electrónico, la validez del caso ante un juez depende enteramente de que los logs de los servidores, los volcados de memoria, las trazas de red, las firmas digitales de las transacciones y los hashes criptográficos de los artefactos hayan sido extraídos e indexados sin alterar su integridad original, garantizando la mismidad de la prueba desde su hallazgo hasta la audiencia de juicio.

8. Dependencias que deben intervenir

En un incidente como el de los ataques al SPEI, la Fiscalía General de la República es la autoridad que normalmente asume la investigación principal. Esto tiene sentido porque se trata de instituciones del sistema financiero y de un sistema de pagos operado a nivel federal por Banco de México. La FGR cuenta con unidades especializadas en delitos cibernéticos que tienen la facultad para llevar este tipo de casos cuando afectan infraestructura crítica.

La Policía Cibernética actuaría como apoyo técnico de la Fiscalía. Su rol sería más operativo: analizar los aplicativos comprometidos, preservar evidencia digital y tratar de identificar cómo se logró el acceso inicial. En la práctica, suelen ser ellos quienes realizan las periciales en informática cuando la Fiscalía les solicita apoyo.

Banco de México ya tuvo una intervención directa desde el momento en que se detectaron los ataques. Emitió comunicados, activó el esquema de contingencia COAS y posteriormente publicó regulación específica para reforzar los controles de las instituciones. La CNBV, por su parte, podría iniciar procedimientos administrativos contra las instituciones afectadas si considera que existieron fallas en sus controles de seguridad, aunque su rol no es investigativo en el sentido penal.

CONDUSEF podría recibir quejas de clientes si alguno considera que sufrió algún perjuicio, aunque el informe de Banco de México fue bastante claro al señalar que los recursos de los clientes no estuvieron en riesgo. Aun así, no es raro que esta dependencia aparezca cuando hay incidentes en el sistema de pagos electrónico.

El tema de las fiscalías estatales es más complicado. Aunque estados como la Ciudad de México, Jalisco o Nuevo León tienen fiscalías especializadas en delitos informáticos, la jurisdicción no es automática. El SPEI es un sistema federal y las instituciones afectadas son participantes del sistema financiero nacional. Esto hace que la FGR tenga una competencia más clara. Sin embargo, si se logra acreditar que los servidores de los aplicativos de conexión se encontraban en un estado específico, o que parte de la conducta se ejecutó dentro de su territorio, una fiscalía estatal podría intentar atraer el caso. En la realidad, estos incidentes suelen quedar en manos de la Fiscalía General de la República por la naturaleza federal del sistema de pagos.

9. Conclusión

El caso de los ataques a los participantes del SPEI deja varias lecciones que van más allá del incidente en sí. Una de las más claras es que la seguridad de un sistema nacional como el SPEI no depende únicamente de la robustez de su núcleo. Cuando los aplicativos de conexión que utilizan las instituciones son desarrollados por terceros y no se someten a controles suficientes, se genera un punto de entrada que puede ser explotado sin necesidad de tocar el sistema central.

En términos de prevención, el propio Banco de México ya había emitido la Circular 14/2017 con requerimientos específicos de ciberseguridad y continuidad operativa que entraron en vigor a inicios de 2018. Sin embargo, el informe reconoce que existía un nivel de cumplimiento heterogéneo entre los participantes. Esto sugiere que muchas instituciones no habían implementado de forma efectiva los procedimientos de gestión de vulnerabilidades, detección de incidentes y resguardo de evidencia que la regulación ya exigía. Si esos controles hubieran estado operando de manera consistente, es probable que el tiempo de exposición de los atacantes hubiera sido menor.

Una lección que vale la pena retomar es el riesgo que representa depender de proveedores externos sin una supervisión adecuada. En la mayoría de los casos documentados, los aplicativos comprometidos no fueron desarrollados por las propias instituciones. Esto no libera de responsabilidad a los bancos, pero sí muestra que la cadena de suministro de software puede convertirse en un vector de ataque significativo cuando no existen mecanismos de revisión y actualización continua.

En el terreno jurídico y procesal, el incidente demostró que la persecución de delitos informáticos en el sector financiero (particularmente bajo las figuras de los artículos 211 Bis 4 y 386 del Código Penal Federal) requiere un cambio de enfoque en la gestión de crisis. Muchas veces las instituciones priorizan restablecer la operatividad y mitigar pérdidas inmediatas, pasando por alto las exigencias de los artículos 227 y 228 del Código Nacional de Procedimientos Penales. Sin una debida preservación de logs, firmas digitales y volcados de memoria bajo estricta cadena de custodia, cualquier esfuerzo por fincar responsabilidades penales se desvanece ante la imposibilidad de sostener la integridad de la prueba digital.

Desde el punto de vista de recomendaciones de ciberseguridad, lo más urgente sería fortalecer los procesos de supervisión que Banco de México realiza sobre los participantes. No basta con emitir regulación; es necesario verificar de forma más

estricta que los controles exigidos realmente se implementen y se mantengan. También sería recomendable que las instituciones adopten prácticas más rigurosas de segmentación de red y monitoreo de sus aplicativos de conexión, especialmente cuando estos son desarrollados por terceros.

En conclusión, este caso demuestra que incluso sistemas críticos bien protegidos en su núcleo pueden verse afectados por fallas en su periferia. La seguridad del SPEI depende en buena medida de que cada participante cumpla de forma efectiva con los estándares técnicos y regulatorios existentes, y de que la respuesta ante incidentes contemple, desde el primer minuto, tanto la recuperación del servicio como la validez forense de la evidencia recabada.

10. Bibliografía

Banco de México. (2018, mayo). *Información sobre los ataques a participantes del Sistema de Pagos Electrónicos Interbancarios (SPEI): Extracto del Informe Trimestral enero–marzo 2018, Recuadro 6, pp. 51–53*.

Hablemos de Ciberseguridad. (s. f.). *¿Qué es MITRE ATT&CK y por qué está en boca de todos en ciberseguridad?* [Video]. YouTube. https://www.youtube.com/watch?v=2eRE-yLoTlM

IIJUNAM. (s. f.). *Derecho informático, comentario: Julio Téllez Valdés* [Video]. YouTube. https://www.youtube.com/watch?v=ubi5DSu06ro

IT Masters News. (2023, 4 de agosto). *Delitos informáticos en México: sanciones* [Video]. YouTube. https://www.youtube.com/watch?v=_o-2fQ3bDRQ

Joel Gómez | Abogado Digital. (s. f.). *Delitos informáticos en México y el mundo* [Video]. YouTube. https://www.youtube.com/watch?v=aTB-540EJTg